个人密码系统架构设计与研究报告

版本 1.0 高层设计评审稿

研究日期 2026 年 11 月 5 日 America Chicago

适用对象 个人使用者及后续开发与安全评审人员

阅读摘要

建议建设一个统一应用，把云同步日常库、可信设备间传输的重要本地库、完全离线冷库分为独立安全域。界面、分类与搜索体验可以统一，密钥、数据库、附件、索引、备份和传输权限必须分开。用户不需要记住密码散落在哪里，系统需要准确告诉用户每个库在哪里、哪些设备可以使用、最近一次备份是否可恢复。

推荐目标架构是本地优先客户端、共享安全核心、平台安全适配器和最小云同步服务。云端负责保存密文、转发变更和登记授权状态；解密、搜索、分类和冲突处理在可信客户端执行。新设备必须通过已授权管理设备批准，或进入明确的离线恢复流程。仅有账户密码、邮箱验证码、设备名称或可复制的设备 ID，均不足以获得保险库访问能力。

不建议直接把 Vaultwarden 换一个界面后宣称满足这些要求，也不建议把普通 KDBX 文件加一个设备列表就称为硬件绑定。现有软件提供了有价值的代码和设计参考，但本项目最核心的设备授权、本地数据边界和恢复规则，需要一致的系统设计。密码算法应使用成熟库与公开规范；授权和同步协议仍需专门评审，不能因采用标准算法就认为整套系统已安全。

首个可用版本建议覆盖 Windows 和 Android，完成云库、本地库、设备批准、离线使用、基本自动填充、备份及恢复。iOS、macOS、Linux 是目标平台，按设备能力分阶段验证；网页端首期只处理不含密码内容的管理操作。重要库的跨设备双向编辑、Passkey 保管、共享和自动化取密随后再加入。

本报告完成了需求分析、官方产品资料研究和开源关键路径静态阅读。没有编写系统功能代码，没有构建或运行所研究项目，没有导入真实密码，也没有完成密码学证明、渗透测试或真实设备验收。下文的架构与指标是推荐方案和验收目标，不是已实现能力。

目录

阅读摘要 1

1 需求边界与使用场景 3

2 产品功能研究及可借鉴设计 4

3 开源源码研究结论 5

4 推荐总体架构 7

5 三类保险库与数据生命周期 8

6 可信设备与密钥架构 10

7 恢复与灾难场景 12

8 数据模型与同步设计 13

9 功能模块与优先级 15

10 跨平台与技术路线 17

11 威胁模型与安全边界 18

12 部署与长期维护 20

13 开源复用与许可证边界 21

14 分阶段实施与决策 22

15 后续验收计划与本轮研究状态 23

附录 A 源码证据索引 25

附录 B 官方产品与平台资料 27

附录 C 许可文件 28

1 需求边界与使用场景

1.1 已明确的目标

用户的主要问题是项目和平台越来越多，账户资料分散，难以查找和维护。系统需要支持个人多设备使用、多级项目分类、云端保存普通资料、本地保存重要资料，并限制未经本人信任的设备访问。此次交付只包含高层架构与功能研究，不包括接口编码、数据库建表、安装部署或真实资料迁移。

本设计默认单一所有者、约 2 至 8 台自有设备，Windows 是首个桌面平台，Android 是首个手机平台；目标覆盖 iOS、macOS、Linux。容量评估以一万条记录及约 1 GB 加密附件作为设计样本，并非已确认的实际数据规模。家庭或团队协作、企业 SSO、公开注册、商业售卖均不进入首版范围。

1.2 需要先统一的词义

概念	本报告中的含义	不应混淆的情况
云同步库	允许密文进入自有或托管服务器，在授权设备之间同步	密文上云仍然属于上云
重要本地库	应用不上传该库及其派生内容，仅向明确授权设备传输	暂时断网或关闭自动同步并不等于从未上云
冷库	保存在指定离线设备或介质，日常手机不持有	不承诺随时随地读取
可信设备	对特定密钥和授权范围完成批准的应用安装实例	设备名称、MAC 地址、系统序列号不是可靠认证秘密
设备绑定	设备私钥由系统或安全硬件保护，复制普通文件不能复制同等能力	普通 key file 和可同步 Passkey 不等于绑定某台主机
解锁	在已获授权设备上允许本地使用库密钥	与云账户登录、云端会话、加入设备不同

“只允许自己的设备”和“所有设备都丢失后能够恢复”存在必要的取舍。本设计允许持有完整离线恢复材料的人重新建立信任；这是一条明确的最高权限路径，不能隐藏成普通的忘记密码功能。

1.3 需求与架构的对应关系

编号	需求	架构处理	后续验收重点
R01	统一保存与查找	统一条目模型、项目树、标签、模板、本地搜索	查找、录入、去重及未知字段保留

编号	需求	架构处理	后续验收重点
R02	手机电脑跨平台	共享核心加平台适配，分阶段交付	实机自动填充与安全存储能力
R03	只有可信设备访问	设备密钥证明、本人批准、按库授权、签名信任记录	密码或会话被盗后的越权测试
R04	普通资料云同步	客户端加密、密文存储、版本化变更	离线修改、冲突、丢包和重放
R05	重要资料不上云	独立存储域、同步进程无读取能力、备份排除	含日志、索引、附件及系统备份的完整检查
R06	项目与系统多级分类	树形目录、稳定 ID、环境字段和多个标签	跨库迁移与普通移动的边界
R07	足够安全	威胁建模、成熟密码组件、最小权限与持续更新	协议评审及独立安全测试
R08	自主管理与可持续使用	自托管、离线恢复、可导出格式、明确兼容策略	服务器消失及客户端停止维护后的恢复

2 产品功能研究及可借鉴设计

本章区分厂商公开说明、源码观察和本项目建议。闭源产品只能研究其公开机制与功能，无法据此确认内部实现完全符合说明，也不代表获得其代码、品牌或界面的使用许可。

2.1 闭源产品的设计启发

产品	经官方资料核实的机制	建议借鉴	不直接沿用的边界
1Password	Secret Key 与账户密码共同保护数据；多库、嵌套标签；独立恢复码路径	人记忆的口令与机器生成的随机秘密分工，分类与库分离	Secret Key 可保存在应用、应急资料或备份中，不是不可复制的设备密钥
Keeper	记录密钥、数据密钥及设备批准；企业 SSO 新设备密钥分发	批准设备时明确授予解密能力，并显示设备授权范围	消费版邮箱验证、企业管理员及自动审批不符合仅本人批准的默认要求
Enpass	按库选择云、Wi-Fi 或文件夹同步；本地加密数据库	每个库有自己的存储策略，附件与记录分开处理	不能默认把重要库密码存进云同步主库；停止同步不清除历史云副本

产品	经官方资料核实的机制	建议借鉴	不直接沿用的边界
RoboForm	多平台填充、应用登录、本地模式及安全分享	清晰的同步状态、填充体验与操作确认	产品中的 Trusted Device 可能指 Passkey 第二因素，不能视为物理设备白名单

产品依据见 [P1] 至 [P10]。本报告不把付费套餐细节作为架构前提，因为自研系统应根据安全边界定义功能，而不是复制厂商的收费划分。

1Password 的高熵 Secret Key 能为服务器数据泄露场景提供额外保护，但它仍是能够保存和迁移的秘密。Keeper 的设备审批示范了“批准”与“发放解密封装”的联系，同时也说明邮箱、管理员和自动化批准都必须纳入信任模型。对本项目，建议由本人管理设备批准，并将离线恢复独立出来。[P1][P2][P4]

Enpass 最贴近本项目的数据分层需求。其按库设置同步位置的思路值得采用，而把额外库密码存入主库的便利选项应默认关闭。对于从云端移回本地的资料，系统只能承诺停止未来上传，不能把历史事实改成“从未上云”。[P6][P7]

2.2 开源产品的功能定位

Bitwarden 的优势是完整跨端产品结构与客户端加密；Vaultwarden 展示了个人规模服务端可以较精简；KeePassXC 展示了本地加密容器、分组、历史和安全保存；KeePassDX 展示了 Android 文件提供器、自动填充和凭据服务的集成方式。它们可以成为设计依据与候选组件来源，但整体授权模型并不相同。[C1][C2][C5][C6][K1][K3][K5]

Proton Pass 的云库和分类机制也有参考价值；但本次源码抽查没有覆盖其密码学及客户端实现，因此不将其列为已评审的技术底座。Strongbox、KeePassium 也不能简单归入闭源产品，本次仅把兼容客户端文档作为参考，没有宣称完成其源码审查。[P11][P12]

3 开源源码研究结论

3.1 研究方法与版本

实际读取了 Bitwarden clients、sdk-internal、server，Vaultwarden，KeePassXC 和 KeePassDX 的关键源文件，固定提交标识见附录。阅读覆盖密钥派生与封装、设备信任、密码登录、同步、本地数据库保存、冲突合并、分类树、Android 文件权限和备份。范围是架构相关抽查，不是全仓库审计。固定开发分支快照不能直接等同于正式发行版本。

3.2 会改变架构选择的发现

代码路径	实际观察	本项目采取的设计
Bitwarden 主密钥与用户密钥	主密码经 KDF 派生后保护随机用户密钥	将口令、库密钥、设备密钥分离；口令修改不等于全部数据轮换
Bitwarden 设备信任	设备公钥包装用户密钥，本地 DeviceKey 保护设备私钥；存在安全存储不可用时的回退	不能把已登记设备直接标为硬件绑定；能力不足时必须明确降级或拒绝
Bitwarden 服务端解密选项	可信设备配置与组织 SSO 有关	个人设备准入独立设计，不依赖企业配置的附带行为
Vaultwarden 密码登录	无批准请求时仍可走正常密码及 2FA，并创建设备记录	默认登录必须检查设备授权，不能保留绕过批准的平行路径
KeePassXC KDBX 写入	整库序列化、加密与认证，部分公开头元数据不加密	KDBX 适合交换和独立备份，但云端记录协议需明确元数据边界
KeePassXC 合并	UUID、时间戳、历史和删除记录共同参与；同时间戳不同内容存在冲突风险	用父版本和唯一变更标识发现冲突，不依靠时间戳静默覆盖
KeePassDX 文件访问	文档 URI 可以指向外部提供器，主清单未声明联网也不能阻止提供器传输	本地重要库使用受控私有路径，不能由任意云文件提供器承载
KeePassDX 保存	先生成加密临时文件，再写入外部提供器	区分本地事务提交与外部存储完成；失败必须保留可恢复副本

直接依据为 [C1] 至 [C7]、[K1] 至 [K6]。以上静态事实只说明所读代码的结构和分支，不表示所有平台、版本和构建配置都表现相同。

3.3 复用原则

建议复用成熟密码库、存储组件和平台接口，借鉴现有产品的模块划分；对自定义设备授权和同步协议单独设计、评审与测试。首版不继承团队组织、企业账户恢复、广泛共享和历史加密格式，以减少与个人需求无关的复杂度。

标准 KDBX 的互操作能力很有价值，但任何获得文件和完整解密材料的兼容客户端都能读取它。严格设备授权要求额外的设备封装与信任协议，现有第三方客户端不会自动执行。因此建议系统运行库采用统一的受控存储引擎；KDBX 作为明确的导入导出和可迁移备份格式候选。若选择直接使用 KDBX 作为重要库，则必须接受更弱的设备约束，并在产品中单独标识。[K1][K2][K7]

4 推荐总体架构

4.1 结构与信任边界

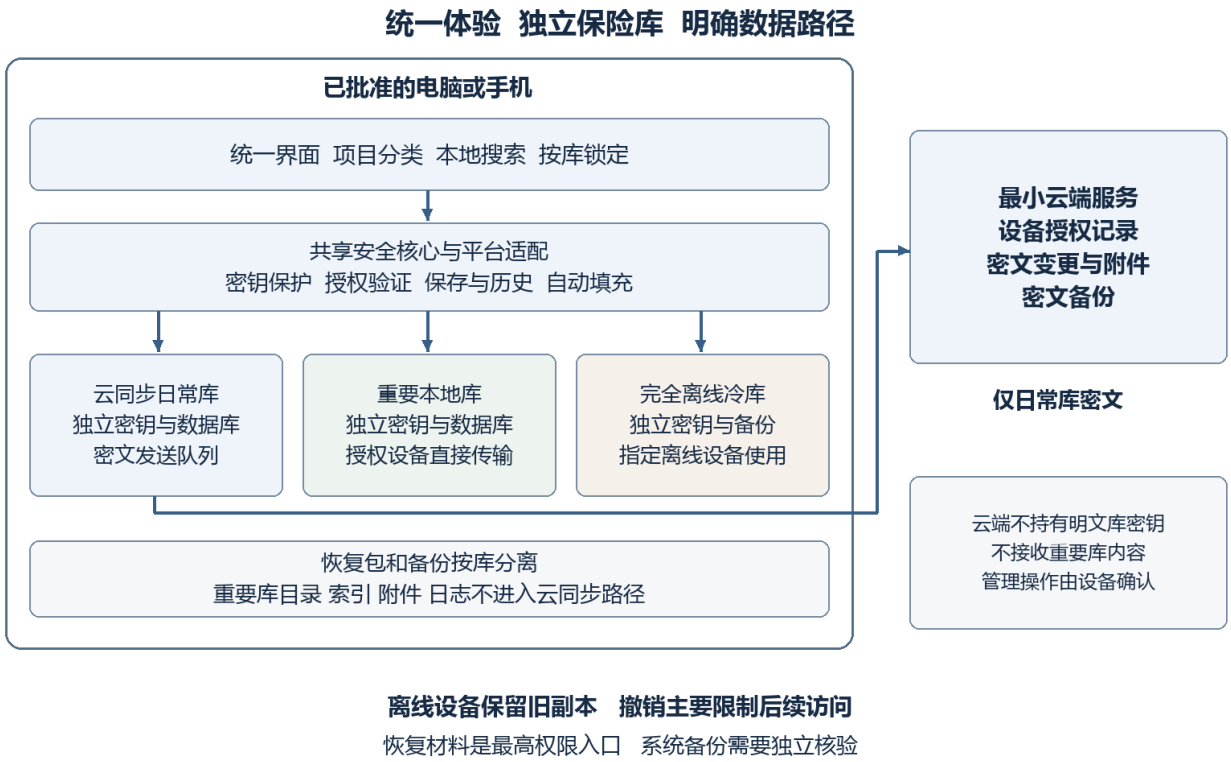


图 1 推荐系统结构。实线表示允许的业务数据路径；本地库没有指向云端的路径。此图是目标设计，不是已部署拓扑。

客户端分为界面、领域模型、安全核心、平台适配和传输适配。安全核心负责密钥生命周期、加解密、签名验证、库策略、数据版本和导入导出校验。平台适配负责 Windows TPM 或系统安全存储、Android Keystore、Apple Keychain 与 Secure Enclave、自动填充和操作系统备份约束。界面不实现密码算法。

日常客户端能够离线打开已获授权的库，云服务不可用不应阻止读取本地已有数据。新设备加入、刷新授权状态和同步仍需要相应连通性。重要库可保持完全不依赖云账户；云端不必知道它的名称、条目、设备授权关系甚至是否存在。

桌面上建议把云传输放在受限进程，只读取云库已提交的密文变更队列。重要库由本地进程和独立路径管理，不给传输进程目录权限。移动端需结合沙箱、服务及扩展能力实现同样的逻辑边界，但同一应用进程完全被攻陷时不能承诺模块隔离仍然可靠。最敏感冷库可进一步使用独立离线配置或专用设备。

4.2 服务端结构

首版采用模块化单体服务，包含设备请求与授权记录、密文同步、加密附件、最少审计事件和备份管理。使用一个关系数据库维护事务状态及变更索引，大附件放独立对象存储或受控文件存储。初期无需微服务、消息总线、全文搜索集群或多区域数据库。

服务端不持有库密钥明文，不执行密码搜索、条目分类、正文解析或明文去重。网络访问控制和客户端密码学验证同时生效：正常服务端阻止未授权访问；即使服务端被控制，客户端仍应拒绝无有效授权、被替换、重放或降级的密钥与记录。签名和校验无法阻止服务器拒绝服务、隐瞒最新数据或对新设备展示陈旧但曾有效的快照，这些限制需要通过可信检查点、恢复资料及告警缩小。

4.3 云端可以知道什么

云端需要知道不透明账户与库标识、设备公钥及授权状态、协议版本、变更位置、对象大小和必要时间信息。项目名称、目录名称、用户名、网址、密码、备注、附件名和用户搜索词默认加密。IP 地址、连接时间、访问频率和密文长度仍可能暴露行为信息；首版不承诺流量匿名化。

网页管理界面不装载完整保险库解密代码，不接收重要库内容。危险操作由已授权原生客户端确认。这样可以减少“服务器被入侵后向浏览器下发恶意解密脚本”的风险；客户端更新渠道仍是独立信任边界，必须签名和保护。

5 三类保险库与数据生命周期

5.1 存储策略

类型	适合资料	允许的数据路径	默认使用方式
云同步日常库	普通网站、低权限测试账户、日常资料	本地加密后上传，授权设备下载	多端读写，支持离线待同步
重要本地库	生产管理账户、主要邮箱、域名及资金相关资料	指定设备间直接传输或加密离线介质；不经过互联网中继	首版一个主写设备，其他设备按需接收只读快照
完全离线冷库	根级恢复材料、极少使用的高权限秘密	指定离线介质与离线恢复流程	不进入手机日常库、不自动填充、不后台同步

本地库跨设备传输首版优先采用加密离线包。后续可加入同一局域网直接连接、二维码核对公钥指纹和双端确认；直接连接失败就报告未传输，不自动回退到云中继。仅传输密文也不符合“任何重要内容都不经过云端”的严格解释，因此该限制包括密文、中间块和附件。

5.2 分类与存储分开

一个条目属于一个保险库，一个主要分类节点，并可具有多个标签。项目、系统、环境、账号角色是组织与查找属性；库类型和授权范围是安全属性。首版支持项目树和标签筛选，避免用深层目录同时表达所有维度。

推荐目录示例为 项目 A / 系统 B / 生产环境，条目记录管理员账号；通过标签标注负责人、自建或第三方、需要二次验证等。跨库搜索只汇总当前已解锁且获授权的本地结果，结果始终显示所属库。不得在云库内留下重要库条目的明文标题、快捷索引或解锁密码。

5.3 跨库迁移与已上云历史

同库换分类只更新组织信息；跨库操作是显式迁移。系统展示目标存储位置、授权设备、附件和历史的处理方式，重新加密到目标库，验证目标可读取后才处理源记录。失败时保留源数据，避免一半移动成功、一半丢失。

从本地移入云库需要本人确认，默认不支持普通拖拽直接上传。从云库移回本地不能撤销既有备份、缓存及接收者副本，应保留“曾进入云端”的来源记录。若用户要求恢复到“秘密从未上云”的状态，需要在原业务系统轮换实际密码或密钥，仅移动数据库条目不足以达到目标。[P7]

5.4 系统备份的特殊限制

应用自身不上传重要库，是可以通过代码与网络验证的目标；操作系统、云盘、第三方备份或具有管理员权限的软件是否复制文件，是另一层问题。Android 的应用备份与设备迁移规则需要分别配置；某些厂商的迁移不完全受单个 allowBackup 开关控制。[A2]

Apple 明确说明，文件的备份排除标志是给系统的指引，并不保证文件从不进入备份。因此普通 iPhone 上仅设置一个 API 标志，不足以承诺重要密文绝不上云。严格模式应要求完成相应设备备份配置核验；无法确认时拒绝导入最高敏感库，或使用受控离线设备。采用不迁移的硬件密钥可提高被意外备份后的保密性，但不能把“备份无法解密”说成“没有上传”。[A3][A4]

Windows 上也需排除 OneDrive 重定向目录、通用备份和剪贴板同步；这些状态应检测和提示，未经授权不自动修改全局系统配置。系统无法阻止所有具有最高权限的软件、恶意操作系统或用户手工复制，这属于明确的不保证范围。

6 可信设备与密钥架构

6.1 四个独立判断

账户身份回答“属于谁”；设备授权回答“这台安装实例可访问哪些库”；库解锁回答“当前是否允许使用本地解密能力”；恢复回答“原设备不可用时凭什么重建权限”。四者使用不同流程和状态，不用一个登录成功标志统管所有权限。

设备名称只是显示信息。设备认证基于随机生成的密钥对和新鲜挑战，设备私钥尽量在安全硬件中生成且不可导出。应用重装或设备迁移后产生新密钥，应视为新设备重新审批。浏览器扩展通过已配对桌面程序使用有限能力，不能仅通过复制浏览器配置取得同等权限。

6.2 设备能力分级

能力级别	证明与保护方式	推荐可用范围
硬件保护且验证充分	使用 TPM、Secure Enclave 或合适的 Android 硬件安全能力；可验证属性按平台记录	云库及获批准的重要库
系统保护但无充分硬件证明	使用系统安全存储，无法证明同等硬件绑定	云库；重要库需用户明确接受降级
普通文件或纯浏览器存储	可复制的应用密钥或没有可靠本地保护	首版拒绝重要库授权；网页不提供保险库解密

硬件保护和远程证明不是同一件事，不能根据客户端自报字段就给出最高等级。Windows、Android 和 Apple 的密钥算法、可用证明、调用方式及失效条件不同，需要具体设备能力验证。Linux 的普通系统钥匙环也不能自动视为 TPM 级保护。[A1][A3][A5]

可同步 Passkey、FIDO2 安全钥匙和设备密钥各有作用。可同步 Passkey 可能在其他认证器出现；外置 FIDO2 钥匙可以插到别的电脑上。因此它们可以加强登录和批准操作，但单独使用不能证明请求来自某台预先登记的电脑。[A6]

6.3 密钥的职责

材料	作用	保存原则
主解锁口令	保护本地解锁材料，提供用户掌握的一层秘密	不上传明文；不作为全部库的唯一云端解密入口

材料	作用	保存原则
设备认证密钥	对挑战和会话绑定进行证明	每设备独立，尽量硬件生成且不可导出
设备解包密钥	打开只发给该设备的库密钥封装	与认证用途区分，按平台验证算法支持
管理授权密钥	签署新增设备、撤销和库授权范围	仅管理设备可用，操作时重新验证本人
每库每代密钥	保护当前代记录密钥及库内结构	云、本地、冷库相互独立，不保存到其他库
记录与附件密钥	隔离对象加密，支持细粒度更新及轮换	由所属库当前代密钥保护
离线恢复材料	恢复库密钥及重建信任所需能力	按库分离，独立离线保存和演练

以上是职责层次，不是可直接照抄的密码协议。推荐评估经过审查的 AEAD 认证加密、Argon2id 口令派生，以及 HPKE 等公开封装方案的成熟实现。密钥用途分离、随机数、nonce 唯一性、关联数据、序列化规范、参数上下限和版本降级防护需要在详细协议阶段固定。[S1][S2]

库密钥的云端副本只能是针对已批准设备的封装，不保留“仅凭主密码即可解密全部库”的云端备用封装。口令用于保护本地解锁能力；严格模式下即使口令泄露，未注册设备仍不能得到库密钥。生物识别快捷解锁可作为本设备上的受控替代路径，不能宣传为每次都同时需要口令和生物识别。

硬件保护通常适用于少量关键密钥操作，不能保证所有密码明文永远不进入内存。显示和填充时仍会出现必要的短暂明文；共享核心应减少复制和存活时间，界面及原生扩展仍需纳入安全审查。

6.4 新设备加入

第一台管理设备在本地创建信任根和库密钥，初始化服务使用一次性、短时、不可重复的注册授权，随后关闭开放引导。不得在公开服务器上保留“谁先注册谁就是管理员”的长期入口。

新设备生成自己的密钥并展示配对请求。本人在已授权管理设备上核对二维码或指纹，确认目标设备、能力级别及可访问的库。批准动作签署设备公钥、库范围、有效策略和当前授权代数，再为该设备生成相应库密钥封装。新设备从可信配对渠道取得并固定信任根，不能只相信服务器返回的公钥。

普通读写设备默认不能批准其他设备；管理设备可以批准云库设备，但不自动获得冷库权限。短期配对请求不得包含密码内容，具有过期和防重放限制。拒绝或过期的申请不留下可重复使用的授权。

6.5 撤销及轮换

撤销设备后，正常服务器立即拒绝其会话、刷新及上传下载，并将签名撤销记录同步给其余设备。发生疑似泄露时，对相关库创建新一代库密钥，只向仍获批准的设备发放。重新封装已泄露的旧记录密钥并不能消除它已被知道的事实；必要时要重新生成记录密钥并重加密当前对象。

若撤销目标包括阻止旧设备读取后续新增或修改内容，则相关记录和附件的后续写入必须使用旧设备不知道的新密钥。仅把旧记录密钥重新包装到新库密钥下不足以达到目标。未变化的旧内容可采用经过评审的惰性重加密策略，但下一次写入必须换钥；已被读取的旧历史风险仍无法收回。

所有授权设备仍需看到最新可信授权状态，才能拒绝被撤销设备的旧签名。离线设备无法实时获知撤销；离线解锁与即时全球撤销不能同时无条件保证。首版允许授权设备离线使用已有数据，并明确显示上次权限核验时间；到期锁定只能约束诚实客户端，不能保证恶意设备擦除旧秘密。

撤销也不会使该设备曾看到的网站密码自动失效。高风险丢失事件需要轮换对应业务系统的实际凭据。冷库和本地库的撤销记录不借云端传播，必须通过其允许的传输或恢复方式分发。

7 恢复与灾难场景

7.1 推荐恢复模型

云库使用离线恢复包，包含恢复所需的加密密钥材料、信任根信息、格式与版本说明；不包含主密码明文，也不让邮箱验证单独授予解密能力。高熵恢复秘密与加密备份分开保存。重要本地库与冷库分别有自己的恢复包，不能把它们合并到云账户恢复材料里。

恢复材料同时能授权新设备时，它就是最高权限凭证。只有邮箱、手机号或服务器管理员权限的人不能重建解密能力；本人遗失所有设备和恢复材料时，系统应明确无法恢复，而不是设置隐藏后门。

7.2 典型事件处理

事件	处理路径	不能保证的部分
一台设备丢失	其他管理设备撤销；必要时轮换库及实际业务凭据	已缓存旧数据无法可靠收回
唯一管理设备丢失	使用离线恢复材料建立新管理设备；复核并撤销旧信任	只有普通读设备不能自行提升为管理员
全部设备丢失	恢复云库密文及离线恢复材料；本地库需独立备份	未备份的本地新修改永久丢失

事件	处理路径	不能保证的部分
忘记解锁口令	已解锁且有适当管理能力的设备执行受控修改，或离线恢复	不假设服务端能发送旧密码
服务器被入侵	停止同步，验证客户端及授权状态，恢复可信服务	无法仅靠重新部署证明此前没有数据泄露
恢复材料泄露	更换恢复授权与相关库密钥，处理实际账号风险	已复制的旧恢复包不会因服务器删除而消失
项目停止维护	使用离线恢复工具和公开格式出口	必须事先验证版本兼容，而非停服后再设计

恢复工具应能在无原服务器情况下读取受支持的备份并导出标准数据；其发布签名、格式说明和必要依赖需与备份一起留存。独立工具仍属于安全产品，不能仅以文档说明代替实际恢复测试。

8 数据模型与同步设计

8.1 核心对象

对象	高层职责	关键约束
保险库	密钥、存储与授权边界	类型、位置及授权范围明确；跨库迁移显式进行
分类节点	表达项目和系统层级	使用稳定 ID 和父节点关系，防止成环
条目	账号、密码、网址、备注和自定义字段	同一条目完整版本一起修改，避免字段混搭
版本与变更	离线修改、历史、冲突与恢复	唯一变更 ID、父版本、作者设备及完整性验证
删除记录	阻止旧设备把已删除内容重新上传	与编辑冲突区分，保留到明确的压缩检查点
附件	独立加密大对象	文件名、类型和密钥不以明文暴露给云服务
设备授权	设备身份、能力、库范围和管理权限	由可信管理主体签名，服务器不能独立扩大权限
同步检查点	标记本设备已经确认的版本位置	防止本设备无提示退回旧状态，不声称解决全部分叉
备份清单	库、版本、附件及恢复要求	可验证完整性，不把重要库清单同步到云库

这张表是领域模型，不是数据库表结构。未知字段和未来格式应保留，或拒绝有损写入；不得默默丢弃。集合在 0、1、N 条记录时保持一致形态。导入与导出需要明确哪些自定义字段、历史、附件和 Passkey 无法无损转换。[K7]

8.2 云库变更流程

编辑先在本机形成新版本并加密，使用事务同时提交本地对象和待发送队列；界面随后显示“已保存本机，等待同步”。网络恢复后上传同一唯一变更，重复请求不能产生重复条目。服务器仅在密文、必要附件及索引提交完成后返回对应确认；客户端再显示“已同步”。

下载后先检查对象归属、授权代数、签名、加密认证和父版本，再解密并事务写入。断电或异常应回到旧的完整版本，或新的完整版本，而不是部分更新。附件先暂存并验证，再使记录引用生效；垃圾回收必须考虑历史与备份引用。

同步服务不解析明文业务内容，无法替客户端判断合并是否合理。不同设备同时修改同一条目时保留双方，显示冲突并由用户选择或人工合并；首版不做会组合用户名和密码的字段级自动合并。设备时钟仅用于展示和辅助排序，不作为唯一覆盖依据。[K3]

8.3 删除与长期离线设备

删除先进入回收站与签名删除记录。目录删除默认保留其条目并要求重新归类；永久清理需要明确操作。删除遇到另一台设备离线编辑时保留冲突，不能自动认为任意一方获胜。

压缩历史或清理删除记录之后，超过支持窗口的旧设备必须从最新检查点完整重同步。其未上传修改进入隔离恢复区，由用户逐项确认后形成新版本，不能直接覆盖当前库或复活已删除记录。被撤销的设备不得借“补传离线修改”恢复写入权限。

8.4 服务器回滚与恶意分叉

每台客户端保存自己确认过的可信检查点，拒绝明显回退；管理操作的签名中绑定授权代数和前序状态。新设备通过已有可信设备获取最新已知检查点。服务器若向不同离线设备提供不同的旧但有效历史，单靠签名不能即时察觉所有分叉。

首版应做到发现不一致后停止自动覆盖并告警，不承诺完全防止恶意服务器分叉。更强的一致性见证或透明日志可以后续研究，但需要额外可信基础和运维成本。备份恢复也可能恢复旧状态，恢复向导必须明确要求复核撤销记录和最近变更。

9 功能模块与优先级

P0 表示接收真实重要凭据前必须完成的基础能力；P1 表示日常可用所需的增强；P2 表示后续扩展。优先级不表示本轮已经实现。

模块	主要功能	优先级	与其他模块的关系
首次初始化	创建所有者、库策略、管理设备和恢复资料	P0	初始化完成须关闭一次性入口
保险库管理	云库、本地库、冷库，独立锁定和设备范围	P0	是存储、备份、搜索及传输边界
密钥与解锁	本地口令、硬件保护、锁定、受控快捷解锁	P0	不向云端提供明文解密材料
设备管理	配对、批准、能力显示、暂停、撤销、重登记	P0	授权变化须与同步和密钥状态一致
条目管理	账号密码、网址、备注、API 密钥模板、自定义字段	P0	首版只保存，不自动注入生产系统
分类与查找	多级项目树、环境字段、标签、收藏、本地搜索	P0	不改变条目的安全域
密码生成	随机密码、口令短语、字符规则	P0	使用系统安全随机数，避免自制随机算法
保存与历史	原子提交、历史、回收站、恢复及未知字段保留	P0	数据安全与加密同等重要
备份与恢复	分库加密备份、恢复包、完整性核验、离线恢复	P0	必须在大规模迁移前完成
云同步	离线队列、幂等上传、冲突、删除记录、状态展示	P0	仅能读取云库密文队列
迁移导入	格式识别、字段映射、预览、去重、分批校验	P0	不自动删除原始数据
基本安全使用	手动显示、复制、锁屏响应、剪贴板清理	P0	清理不保证其他应用没有复制
自动填充	浏览器桥接、Android 服务、匹配与用户确认	P1	单次最小披露，重要库默认逐次确认

模块	主要功能	优先级	与其他模块的关系
附件	独立加密、限额、下载校验及受控打开	P1	外部查看器可能产生副本，打开时明确说明
安全检查	本地弱密码和重复密码提示，过期提醒	P1	外部泄露查询默认关闭或明确授权
安全事件	设备批准、撤销、导出和恢复记录	P0	无密码、网址、搜索词或敏感标题日志
运维与更新	备份监测、签名更新、兼容迁移及故障恢复	P0	不依赖第三方行为分析 SDK
近距离传输	同一局域网直连、核对指纹、只读快照	P1	不能自动转为云中继
TOTP	验证码种子保存及生成	P1	重要账户可选择将第二因素独立保存
Passkey 保管	创建、保存、填充及迁移	P2	区分网站 Passkey 与系统设备认证密钥
SSH 与开发工具	SSH agent、限权 API、环境变量或短期取密	P2	每个调用方单独授权和审计
分享与应急联系人	指定对象、时限、撤销后续访问	P2	会扩大可信主体，首版关闭

9.1 关键交互流程

首页以保险库为边界显示锁定、位置、授权设备、同步或备份状态；项目视图在此基础上聚合。每个条目都能看到所属库，创建时清楚选择存储范围。系统可以记住某个项目的上次选择，但不能把重要库条目静默改为云库。

设备界面展示本人赋予的名字、系统类型、密钥指纹、能力验证结果、允许的库、是否拥有批准权限和最后核验时间。批准请求显示具体范围，不用只有“是否信任这台设备”的笼统按钮。

保存、同步和备份是三种状态。离线保存成功不显示“已备份”；服务端收到数据也不表示另一台手机已经应用；只有做过恢复校验才能显示备份可恢复。出现冲突时保留可解释的来源和版本，不直接要求用户理解底层日志。

9.2 自动填充的保护范围

浏览器扩展首期通过 Native Messaging 等平台桥接能力调用桌面客户端，仅获取与当前站点和用户本次操作对应的记录，不持有完整库密钥。扩展身份、来源页面、顶层页面与 iframe 关系都需要验证；网页内容脚本的输入不能直接转发成任意本机命令。[A7]

Android 需要原生自动填充与凭据提供服务；iOS 需要 Credential Provider Extension。共用跨平台界面不能替代这些原生扩展。重要库默认不预先暴露大量账号提示，具体平台的建议索引和 App Group 共享范围也要纳入保护。[A8][A9]

不得为了便利在日志、错误报告、通知、站点图标请求、剪贴板历史、系统搜索索引或大模型调用中发送重要信息。首版关闭在线图标抓取和云端 AI 整理；后续如加入智能分类，优先纯本地处理，且不改变存储策略。

10 跨平台与技术路线

10.1 推荐候选组合

共享安全与数据核心优先评估 Rust，界面优先评估 Flutter，Android 和 Apple 扩展保留原生 Kotlin / Swift 适配；Windows 通过系统 API 对接密钥保护和桌面桥接。Flutter 官方支持移动与桌面多平台，但每个平台的安全能力和扩展权限仍需独立验证。[A10]

这一组合的理由是把关键规则集中到一个可审查核心，减少不同端加密、迁移和冲突处理不一致。代价是跨语言桥接、内存中的秘密副本、移动扩展生命周期及构建分发更复杂。Rust 能减少一类内存错误，不能自动解决协议错误、日志泄密或界面误操作。

服务端可以选择团队熟悉的 Rust 或 Go，并保持模块化单体；本设计暂不锁定框架、数据库版本或密码库版本。库选型必须核查维护状态、独立审查记录、平台能力和许可证，不能因为编程语言一致就复用不合适的 SDK。

10.2 平台能力规划

平台	首期目标	必须单独验证的内容
Windows	完整云库和本地库，主写与管理设备，浏览器桥接	TPM / CNG、系统锁定、应用签名、备份与剪贴板同步
Android	云库读写、本地快照、设备批准、基础填充	Keystore 实际级别、厂商后台限制、备份与设备迁移

平台	首期目标	必须单独验证的内容
iOS	后续同等核心能力，原生填充扩展	Secure Enclave / Keychain、扩展内存预算、备份限制及分发
macOS	后续桌面管理与自动填充	Keychain、Secure Enclave 设备差异、签名与公证
Linux	后续云库与本地库	桌面钥匙环与 TPM 能力差异，不能静默弱化设备保护
浏览器	先作为已配对桌面程序的有限入口	扩展更新、来源验证、iframe 与钓鱼页面
网页端	首期只提供有限管理和状态	不成为绕过设备批准的完整解密端

全平台是产品路线，不表示所有平台必须以同一进度交付。重要库应按能力而非仅按操作系统名称决定能否使用。对于硬件能力不足的旧设备，可以提供云库兼容模式，但需要明确标签，不能仍宣称相同强度的设备绑定。

10.3 三种实施路线的取舍

路线	收益	主要成本	建议
基于 Vaultwarden 与现有客户端	日常密码功能最快可用	强制设备授权需要改客户端、服务端和恢复流程，独立本地库另做	适合验证交互需求，不作为本需求完整架构的最终捷径
基于 KeePass 兼容客户端和文件同步	现成格式和离线恢复，数据可迁移性好	强设备准入、多端同步及统一体验受原模型限制	可作低成本替代，但须接受安全能力边界
自建共享核心和产品层	库策略、设备授权与界面一致可控	协议、跨平台、安全测试和长期维护投入最大	与用户自建目标最一致，采用成熟组件并严格分阶段

11 威胁模型与安全边界

保护对象包括账号秘密、恢复材料、库密钥、设备密钥、项目与网址元数据，以及数据的完整性和可用性。默认考虑互联网攻击者、被盗云数据库、恶意或被控制的服务器、遗失设备、恶意网页、错误同步和供应链更新风险。

场景	目标防护	剩余边界
只盗取服务器数据库	密文及设备封装不能直接解密；限制口令猜测入口	元数据、流量与旧密文仍可能泄露
主密码泄露	未批准设备没有设备密钥和库授权	若同一可信设备也被控制，风险显著增加
登录会话被复制	会话绑定设备证明；高风险操作重新确认	单独的 Bearer token 不足以实现强设备约束
服务器替换设备公钥	批准绑定指纹、可信信任根和签名记录	初始可信渠道本身必须可靠
服务器篡改或重放记录	AEAD、对象归属绑定、版本及签名检查	无法阻止全部拒绝服务或对新设备隐瞒最新版本
设备锁定时丢失	磁盘保护、硬件密钥、应用锁及远程停止同步	已解锁副本、弱锁屏或恶意系统仍有风险
设备运行恶意软件	最小权限、短暂明文、按次填充及签名更新	无法保证对抗已控制系统或读取显示内容的攻击者
同步冲突或断电	事务、幂等、冲突保留、校验与恢复	未完成备份的离线新数据可能丢失
更新渠道被控制	独立签名、可信版本策略、分阶段升级	签名密钥泄露是严重事件，需要撤销和恢复机制
重要库意外进入云备份	私有路径、备份规则及设备条件核验	应用不能控制所有第三方备份或管理员行为

公开安全研究已经说明，仅宣传“零知识”不足以证明恶意服务器无法影响客户端。2026 年 ePrint 更新版分析了四个云密码产品并讨论了密钥、完整性及恢复路径问题。本项目应把服务器主动作恶纳入设计，而不是只考虑数据库文件被偷；这些研究不代表所涉产品当前版本所有问题仍未修复，也不证明本设计已解决它们。[S3]

11.1 首版默认策略

建议默认屏幕锁定立即锁库，后台超时锁定，重要库显示或填充时再次确认；具体超时可设置。密码显示默认遮挡，剪贴板短时清理并尽量禁止系统同步，导出需要重新验证。不能把定时清理说成能够擦除其他应用已保存的副本。

日志只记录事件类别、不透明对象标识、版本和错误码。崩溃转储、诊断包和外部监控均需脱敏；默认不上传。数据库事务日志、临时附件和搜索索引同样受保护。UI 内存无法保证完全无痕，安全评审应覆盖截图、辅助功能和通知泄露，而不是只看数据库加密。

11.2 不作出的承诺

不承诺绝对安全、所有硬件同等级安全、离线设备实时撤销、曾复制数据远程消失、重要资料在任意操作系统上绝不被任何软件备份，也不承诺从云端删除后所有历史副本已经物理消失。SSD、文件系统快照和外部备份使彻底擦除难以证明；密钥销毁也只对未被复制的相应密钥与密文关系有效。

12 部署与长期维护

12.1 推荐初始部署

使用独立的小型服务实例和最少端口。可选择自有主机或云主机，但不与高频试验、公开游戏服务和任意脚本执行环境共享同一安全边界。不同容器或域名不一定构成充分隔离；若共用同一操作系统管理员权限，主机失陷仍会同时影响服务。

私有组网可以作为附加访问层，降低公网暴露；应用仍必须检查设备授权和密文完整性。私有网络加入成功不等于获得库密钥，公网 HTTPS 也不等于设备认证。具体组网方案、国内网络稳定性、IPv6 与移动后台兼容性在原型阶段验证，本报告不依赖某一家免费套餐长期不变。

服务数据库、加密附件和授权记录需要一致备份。备份存储账号与运行服务账号尽量分离，保留有限历史版本。离线客户端也需要独立备份，因为云端同步可能同步误删；重要本地库的备份不复用云服务备份路径。

12.2 更新与兼容性

客户端、浏览器扩展、移动扩展和服务器有独立发布版本，协议声明支持范围。格式升级先备份并验证迁移，旧客户端遇到不支持的写入格式应拒绝写入；不能为了兼容而丢弃未知字段。安全修复可能要求最低版本，用户应能看到为何必须升级。

发布签名密钥与普通构建、服务器凭据隔离；依赖固定版本并保留组件清单。构建、签名、备份和恢复流程均属于长期维护范围。所谓回滚是恢复到经过验证的兼容版本，不能为了修复界面问题而降回已知不安全的协议或数据格式。

12.3 建议目标及成本

以下为原型后的候选验收目标：一万条测试数据时本地搜索 p95 不超过 300 毫秒；正常本地提交不等待网络；在预先约定的良好网络中，小变更同步可见时间目标为 5 秒。实际解锁耗时由口令派生强度与最弱支持设备共同校准，不能为追求表面速度降低保护。

云库恢复点取决于已成功同步并完成备份的最后变更；离线新修改不在服务器恢复保证内。重要库建议每次重大变更后做离线备份，日常最长备份间隔先以 24 小时为目标。备份齐备时，单设备恢复目标为 2 小时，服务器重建目标为 4 小时，均需演练后确认。

软件许可免费不代表自建成本为零。成本主要来自工程时间、真实设备、硬件安全钥匙、服务器与备份、平台签名和分发，以及外部安全审查。当前尚未确定设备清单、部署地点及商业发行计划，不给出伪精确的人民币报价；硬件采购或服务付费需另行决策。

13 开源复用与许可证边界

开源源码可见不等于所有目录都能任意嵌入闭源应用。Bitwarden clients、server 和 SDK 存在不同许可及单独目录；Vaultwarden、KeePassXC、KeePassDX 也有各自的 copyleft 条件和第三方组件。本次读取了相关许可文件，不能仅看项目首页的“开源”标识决定复用。[L1] 至 [L6]

复用方式	对本项目的价值	需要先核对
研究行为后独立实现	能适应本项目的库策略和设备模型	不复制受限代码、资源和品牌；维护自己的设计证据
兼容公开交换格式	减少数据锁定，便于退出	版本、扩展字段及有损转换边界
引入底层开源库	降低算法与格式实现风险	精确许可证、审查记录、维护状态及接口能力
fork 整个产品	快速获得大量现成功能	分发与网络使用义务、专有目录、长期跟进上游成本

建议先按可公开发布的独立产品设计，自研产品流程，选择许可明确的基础组件；暂不承诺最终开源或闭源形式，也不预先复制 Bitwarden SDK 或 KeePass 应用代码。未来若商业发行，应以实际依赖和分发方式进行专业许可及必要的专利核查。本章是工程风险提示，不是对具体分发行为的法律结论。

14 分阶段实施与决策

14.1 建议阶段

阶段	交付范围	退出条件	粗略工作量
A 安全与平台验证	固定威胁模型，验证设备密钥、备份条件、配对与恢复技术路径	Windows 和目标手机能证明关键能力与限制	2 至 4 人周
B 本地单机基础	独立库、分类、条目、锁定、历史、导入导出及离线恢复	无真实秘密的故障恢复和格式验证完成	4 至 6 人周
C 云同步与设备授权	密文服务、批准与撤销、云库离线编辑、冲突、管理操作	恶意响应与授权旁路测试完成	6 至 10 人周
D Windows 与 Android 日常使用	自动填充、移动适配、本地快照传输、备份体验	两类设备的真实场景验收完成	6 至 10 人周
E 安全评审与有限迁移	外部安全评审、修复、恢复演练、分批迁移	关键风险处理完毕，有可用回退与退出方案	4 至 8 人周

合计约 22 至 38 人周，是本报告对个人版可用基础范围的初步工程估计，不是承诺工期，也不包含所有 P2 功能。Apple 与 Linux 的完善支持可能再增加约 10 至 20 人周，取决于设备、原生扩展和分发方案。独立开发者的日历时间还受维护、测试、等待审查和平台账号影响；增加 AI 辅助不能替代真机与安全评审。

阶段 A 至 E 是后续执行建议，本轮没有开始实现。首版接收真实重要资料前，恢复、备份及安全边界必须完成验证；不能先迁入全部凭据，再补恢复机制。

14.2 建议采用的默认决策

默认一个所有者；Windows 加 Android 起步；统一应用分三类独立库；重要库首版单主写；手机仅接收明确批准的快照；不做公开注册；无邮箱单独恢复；网页不解密；不做团队共享；不向 AI 或监控平台发送内容。这些是为了使第一版范围可完成的建议，并未将未确认偏好当作用户已决定。

后续详细设计前，需要确认手机系统和型号、重要库是否必须手机可写、对 Linux 支持的优先级、是否允许普通库使用云服务，以及未来是否向他人分发。它们会影响平台顺序、密钥能力、同步复杂度与许可证选择。即使这些问题暂未决定，独立安全域和恢复边界仍然成立。

15 后续验收计划与本轮研究状态

15.1 按直接风险验收

验收场景	必须观察到的结果	当前状态
只有密码或邮箱验证码的新设备	无法获得库授权或解密材料	not run
服务端伪造新设备或扩大库范围	客户端因签名或信任根不匹配拒绝	not run
复制安装目录及浏览器配置	不能复制最高级设备绑定能力	not run
恢复旧手机或系统备份	不静默恢复原设备身份；需重新授权	not run
重要库全路径检查	应用传输、索引、附件、日志和诊断均无云上传	not run
系统备份与厂商换机	实际行为符合该设备能力声明；不符即拒绝严格模式	not run
离线并发修改与删除	保留冲突，不丢记录，不静默复活删除项	not run
同时改密码和账号字段	版本完整，不产生错误字段组合	not run
断电、磁盘满及网络中断	保留可打开的完整版本和清楚错误状态	not run
撤销后旧设备重连	无新同步权限；旧离线副本限制如实展示	not run
服务器回滚及旧格式响应	发现已知回退或不支持格式，停止不安全写入	not run
所有设备丢失	可凭独立备份和恢复材料重建；缺失时明确无法恢复	not run
导入导出 0 1 N 条	集合形态一致，计数与字段保留可核对	not run
不可信网站和扩展请求	未经确认不填充错误站点、不越权读取全库	not run

验收场景	必须观察到的结果	当前状态
客户端更新和版本迁移	签名、兼容、备份及失败恢复均经过验证	not run

这是一份验收设计，不是测试结果。故障注入、服务器主动作恶、设备克隆、恢复与自动填充测试必须使用虚构资料；关键路径验证完成后再逐步迁移真实低风险账号，最后处理重要资料。

15.2 本轮证据状态

工作项	状态	证据与限制
需求与使用场景整理	pass	已形成需求映射、默认假设和待确认事项
闭源产品公开资料研究	pass	已引用官方说明；没有声称审查闭源实现
开源关键路径阅读	pass	六个仓库固定提交，具体文件见附录
完整源码审计	not run	仅抽查架构相关路径，未构建或运行
高层架构与功能模块	pass	已形成候选设计、取舍和分阶段范围
硬件及操作系统兼容性	not run	依据官方能力说明，尚无目标设备测试
密码学协议安全评审	not run	当前仅定义职责和约束，不能作为实现规范
系统实现和正式上线	not run	本轮明确不编写系统功能代码、不部署
是否可以托管真实重要密码	blocked	设计文档不是可运行系统，需完成实现及相应验收

报告建议的下一份工程交付是详细安全协议与平台能力验证方案，先固定设备注册、撤销、恢复和本地存储边界，再编写系统功能。这样可以避免界面和同步已经开发完成，才发现恢复方式或手机备份规则与最初安全目标冲突。

附录 A 源码证据索引

所有源码链接指向本次实际阅读的固定提交，取自检索时的开发分支快照。行号会因显示方式变化，以下以文件和符号为主要定位依据。本附录不包含复制的大段源码。

仓库	固定提交	阅读范围
bitwarden clients	ce4c396d4bd4e6f20539934d9d1dd20921e75321	设备信任、同步、条目写入和许可证
bitwarden sdk internal	273366af5b344d3c4b91c64fadf552e88fa7697a	主密钥派生、随机用户密钥及许可证
bitwarden server	7e6de5527a65a1479c4fc85d3a7466bc6ab4723c	可信设备选项、设备停用和许可证
dani garcia vaultwarden	17b159beff4b892f07f61f38ce2fe452e55251c1	密码登录、设备建立、批准及模型
keepassxreboot keepassxc	6bcb901aefdd6c7a525466d7dfe099c5ebc13c0e	密钥组合、格式、保存、合并和分组
Kunzisoft KeePassDX	77ecfa8654a5bd0d79d512f8fa71c0af8a29b554	文件提供器、保存、权限和备份

源码检索于本轮完成，时间约为 2026 年 11 月 6 日 UTC；报告日期按用户客户端 America Chicago 记为 11 月 5 日。未把开发分支提交号作为推荐安装版本。

云端项目源码

[C1] Bitwarden 主密钥实现 读取 MasterKey::derive、make_user_key 和 HashPurpose，观察派生与随机用户密钥封装。

[C2] Bitwarden 设备信任服务 读取 trustDevice、getDeviceKey 和 setDeviceKey，观察设备封装及安全存储回退。

[C3] Bitwarden 解密选项构建 读取 BuildTrustedDeviceOptionsAsync，观察 SSO 配置边界。

[C4] Bitwarden 设备服务 读取 DeactivateAsync 与 UpdateDevicesTrustAsync，观察服务端撤销和封装更新。

[C5] Bitwarden 同步实现 读取 fullSync、syncProfile 和 syncCiphers，观察密钥处理顺序、状态与本地集合替换。

[C6] Vaultwarden 登录与设备创建 读取 password_login 和 get_device，观察普通密码路径及新设备创建。

[C7] Vaultwarden 设备批准 与 条目模型 用于确认授权记录及服务端元数据边界。

本地项目源码和格式

[K1] KeePassXC 密钥组合 与 文件密钥 读取 rawKey、transform、challenge、load 与 loadHashed。

[K2] KeePassXC KDBX4 写入 读取 writeDatabase、writeAttachments 和公开头写入，确认整库、附件与元数据边界。

[K3] KeePassXC 合并 读取 resolveEntryConflict_MergeHistories、mergeHistory、mergeDeletions。

[K4] KeePassXC 保存 与 分类树 读取 saveAs、performSave、setParent 和 groupsRecursive。

[K5] KeePassDX 主清单 与 文档 URI 处理，观察权限及外部文件路径。

[K6] KeePassDX 保存任务、数据库保存 与 备份规则，确认临时文件和备份规则的范围。

[K7] KeePass KDBX 格式说明 与 同步说明，辅助研究格式兼容、未知字段和整条目同步。

附录 B 官方产品与平台资料

下列网页为本轮读取的公开资料，功能与套餐可能变化；旧版白皮书已标注，不将其所有参数当作当前发行版实现。文内编号对应来源，网络链接可直接打开。

产品资料

[P1] 1Password Secret Key 安全说明 设备生成的附加秘密、保存及迁移途径；页面标注更新于 2026 年 10 月 6 日。

[P2] 1Password 恢复码安全说明 研究独立恢复封装与身份验证边界。

[P3] 1Password 标签和收藏 与 升级至 1Password 8，研究分类与账户库定位。

[P4] Keeper 安全架构 与 SSO 设备批准，区分消费版身份验证和企业密钥批准流程。

[P5] Keeper iOS 使用说明，研究本地解锁与云同步验证的差异。

[P6] Enpass 多保险库 与 文件夹离线同步，研究每库存储策略及额外库密码保存选项。

[P7] Enpass 停止保险库同步，明确停止同步不自动移除既有云数据。

[P8] Enpass 安全白皮书 正文版本 1.4，标注 2025 年 8 月 22 日；用于研究本地数据库、附件及同步职责。

[P9] RoboForm 可信设备或硬件钥匙验证 与 关闭自动同步，研究术语和同步设置边界。

[P10] RoboForm 安全白皮书 正文版本 1.9，标注 2023 年 2 月；只作机制参考，不作为当前全部参数的验证。

[P11] Proton Pass 文件夹说明，研究多库内分类及功能限制；本轮未阅读其源码。

[P12] Strongbox 官方介绍 与 KeePassXC 兼容客户端说明，用于区分开源兼容生态与闭源产品。

平台能力与标准

[A1] Android Keystore，硬件支持、不可导出能力和被攻陷进程仍可能调用密钥的边界。

[A2] Android Auto Backup，云备份、设备间传输和厂商差异。

[A3] Apple Secure Enclave 密钥保护 与 ThisDeviceOnly 访问级别，设备密钥与迁移边界。

[A4] Apple iCloud Backup 数据管理，说明备份排除标志并非绝对保证。

[A5] Windows 如何使用 TPM，研究 Platform Crypto Provider 和不可导出密钥。

[A6] WebAuthn Level 3，研究备份资格、单设备凭据与多设备凭据区别。

[A7] Chrome Native Messaging，原生桥接、允许来源及内容脚本校验要求。

[A8] Android 凭据提供服务，研究与自动填充及 Passkey 集成的原生边界。

[A9] Apple Credential Provider 与 凭据建议索引，研究扩展与敏感元数据。

[A10] Flutter 支持平台，仅证明框架的平台覆盖，不证明应用安全能力或功能已验证。

[S1] RFC 9106 Argon2，口令派生候选及参数校准依据。

[S2] RFC 9180 HPKE，密钥封装候选；本报告未选择具体实现或声称已完成协议证明。

[S3] Zero Knowledge About Encryption 研究，2026 年 8 月 12 日更新版覆盖四个云密码产品；用于说明恶意服务器威胁与协议审查必要性。

附录 C 许可文件

[L1] Bitwarden clients 许可 默认 GPLv3，特定目录另有许可。

[L2] Bitwarden server 许可 默认 AGPLv3，特定目录另有许可。

[L3] Bitwarden SDK 许可 与 SDK License，需要按文件及使用方式核对限制。

[L4] Vaultwarden 许可 AGPLv3。

[L5] KeePassXC 许可 项目主要使用 GPL2 或 GPL3，附带其他许可组件。

[L6] KeePassDX 许可 与所读源码头所示 GPL3 或后续版本。

许可摘要仅标明复用前需要检查的边界。实际是否触发分发、提供源代码或其他义务，应按最终代码来源、链接方式、运行及分发场景核定。